

REPORT DI THREAT INTELLIGENCE

IDENTIFICAZIONE IOC E ANALISI DEL TRAFFICO DI RETE

OBIETTIVO

L'obiettivo di questo esercizio era analizzare una cattura di rete effettuata con Wireshark, identificare eventuali **Indicatori di Compromissione (IOC)**, formulare ipotesi sui vettori di attacco utilizzati e proporre azioni concrete per mitigare l'attacco rilevato e prevenirne di simili in futuro.

SCENARIO

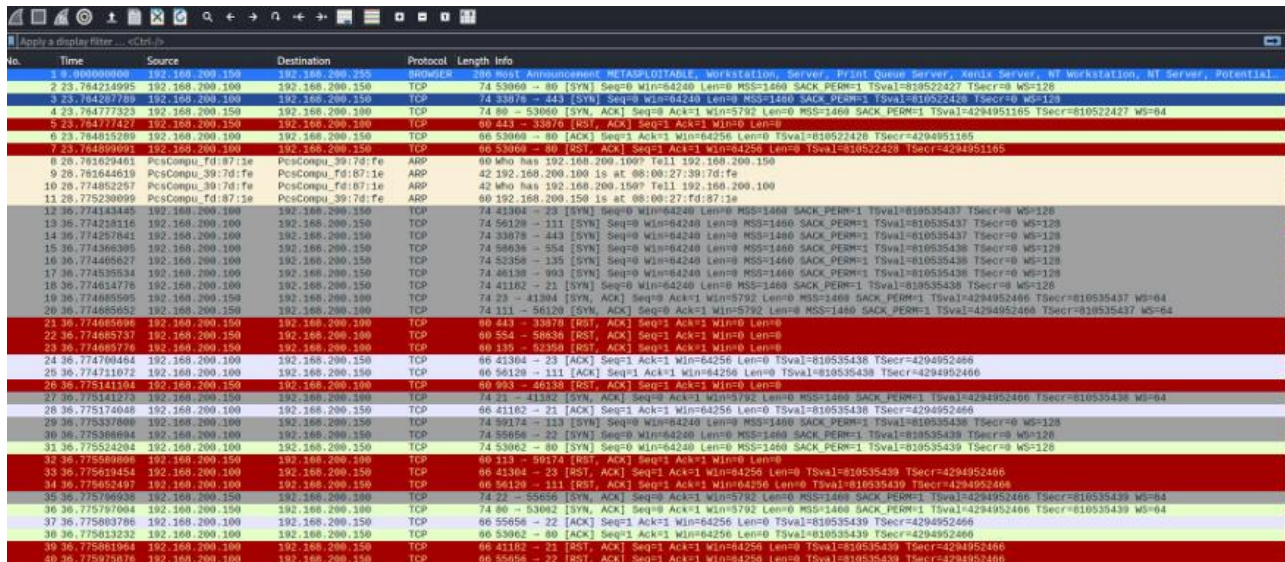
La cattura analizzata coinvolge due macchine all'interno della stessa rete locale:

- **192.168.200.100**: macchina attaccante
- **192.168.200.150**: macchina vittima, identificata come Metasploitable

Il file **.pcapng** è stato aperto direttamente su Kali Linux con *Wireshark*, dopo aver spostato il file tramite cartella condivisa VirtualBox e aver assegnato i permessi necessari all'utente kali.

ANALISI DELLA CATTURA

Aprendo la cattura, la prima cosa che ho notato è stata il primo pacchetto in assoluto: un annuncio NetBIOS di tipo BROWSER in cui la vittima si presentava sulla rete come "METASPLOITABLE", dichiarando il proprio ruolo (Workstation, Server, Print Queue Server e altri).



No.	Time	Source	Destination	Protocol	Length	Info
1	0.000000000	192.168.200.150	192.168.200.255	BROWSER	286	Host Announcement METASPLOITABLE, Workstation, Server, Print Queue Server, Admin Server, NT Workstation, NT Server, Potential
2	23.784214995	192.168.200.100	192.168.200.150	TCP	74	53060 → 80 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=810522427 TSecr=0 WS=128
3	13.784207739	192.168.200.100	192.168.200.150	TCP	74	53076 → 443 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=810522426 TSecr=0 WS=128
4	23.784277323	192.168.200.150	192.168.200.100	TCP	74	80 → 53060 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM=1 TSval=4294951105 TSecr=810522427 WS=64
5	23.784777427	192.168.200.150	192.168.200.100	TCP	60	443 → 33876 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
6	23.784815289	192.168.200.100	192.168.200.150	TCP	60	53060 → 80 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810522428 TSecr=4294951105
7	23.784819091	192.168.200.100	192.168.200.150	TCP	60	53060 → 80 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0 TSval=810522429 TSecr=4294951105
8	28.781629451	PcsCompu, fd:87:fe	PcsCompu, 39:7d:fe	ARP	60	Who has 192.168.200.100? Tell 192.168.200.150
9	28.781644619	PcsCompu, 39:7d:fe	PcsCompu, fd:87:fe	ARP	42	192.168.200.100 is at 08:00:27:39:7d:fe
10	28.774852257	PcsCompu, 39:7d:fe	PcsCompu, fd:87:fe	ARP	42	Who has 192.168.200.150? Tell 192.168.200.100
11	28.775230099	PcsCompu, fd:87:fe	PcsCompu, 39:7d:fe	ARP	60	192.168.200.150 is at 08:00:27:fd:87:fe
12	36.774813845	192.168.200.100	192.168.200.150	TCP	74	41304 → 23 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=810535437 TSecr=0 WS=128
13	36.774213316	192.168.200.100	192.168.200.150	TCP	74	56128 → 111 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=810535437 TSecr=0 WS=128
14	36.774257841	192.168.200.100	192.168.200.150	TCP	74	33876 → 443 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=810535438 TSecr=0 WS=128
15	36.774368395	192.168.200.100	192.168.200.150	TCP	74	56836 → 554 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=810535438 TSecr=0 WS=128
16	36.774465627	192.168.200.100	192.168.200.150	TCP	74	52356 → 135 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=810535438 TSecr=0 WS=128
17	36.774325534	192.168.200.100	192.168.200.150	TCP	74	46138 → 963 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=810535438 TSecr=0 WS=128
18	36.774614776	192.168.200.100	192.168.200.150	TCP	74	41182 → 21 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=810535438 TSecr=0 WS=128
19	36.774685595	192.168.200.150	192.168.200.100	TCP	74	23 → 41304 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM=1 TSval=4294952466 TSecr=810535437 WS=64
20	36.774685652	192.168.200.150	192.168.200.100	TCP	74	111 → 56128 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM=1 TSval=4294952466 TSecr=810535437 WS=64
21	36.774685698	192.168.200.150	192.168.200.100	TCP	60	443 → 33876 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
22	36.774685737	192.168.200.150	192.168.200.100	TCP	60	554 → 56836 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
23	36.774685776	192.168.200.150	192.168.200.100	TCP	60	135 → 52356 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
24	36.774700484	192.168.200.100	192.168.200.150	TCP	60	41304 → 23 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535438 TSecr=4294952466
25	36.774711072	192.168.200.100	192.168.200.150	TCP	60	56128 → 111 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535438 TSecr=4294952466
26	36.775141151	192.168.200.150	192.168.200.100	TCP	60	80 → 53060 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM=1 TSval=4294952466 TSecr=810535438 WS=64
27	36.775141273	192.168.200.150	192.168.200.100	TCP	74	21 → 41182 [SYN, ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535438 TSecr=4294952466
28	36.775174048	192.168.200.100	192.168.200.150	TCP	60	41182 → 21 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535438 TSecr=4294952466
29	36.775337088	192.168.200.100	192.168.200.150	TCP	74	59174 → 113 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=810535438 TSecr=0 WS=128
30	36.775368994	192.168.200.100	192.168.200.150	TCP	74	55956 → 22 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=810535439 TSecr=0 WS=128
31	36.775524294	192.168.200.100	192.168.200.150	TCP	74	53062 → 80 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=810535439 TSecr=0 WS=128
32	36.775589896	192.168.200.150	192.168.200.100	TCP	60	113 → 59174 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
33	36.775613454	192.168.200.100	192.168.200.150	TCP	60	41304 → 23 [RST, ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535439 TSecr=4294952466
34	36.775624937	192.168.200.100	192.168.200.150	TCP	60	56128 → 111 [RST, ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535439 TSecr=4294952466
35	36.775706995	192.168.200.150	192.168.200.100	TCP	74	22 → 55956 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM=1 TSval=4294952466 TSecr=810535439 WS=64
36	36.775717004	192.168.200.150	192.168.200.100	TCP	74	80 → 53062 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM=1 TSval=4294952466 TSecr=810535439 WS=64
37	36.775803786	192.168.200.100	192.168.200.150	TCP	60	55956 → 22 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535439 TSecr=4294952466
38	36.775813232	192.168.200.100	192.168.200.150	TCP	60	53062 → 80 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535439 TSecr=4294952466
39	36.775818042	192.168.200.150	192.168.200.100	TCP	60	41182 → 21 [RST, ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535439 TSecr=4294952466
40	36.775975876	192.168.200.100	192.168.200.150	TCP	60	55956 → 22 [RST, ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535439 TSecr=4294952466

Scorrendo la cattura ho individuato subito un pattern anomalo: decine di pacchetti **TCP** con flag **SYN** inviati da 192.168.200.100 verso 192.168.200.150, tutti verso **porte diverse**, in una finestra temporale di pochi decimi di secondo. La macchina vittima rispondeva sistematicamente con **RST/ACK** sulle porte chiuse, mentre sulle porte aperte il **three-way handshake** veniva **completato regolarmente** (SYN, SYN/ACK, ACK). Quindi ho realizzato che si tratta di una *nmmap* aggressivo.

Per isolare le porte aperte ho applicato un filtro mirato, visualizzando solo i pacchetti ACK puri (senza SYN e senza RST) inviati dall'attaccante verso la vittima, che corrispondono al completamento del three-way handshake:

- `tcp.flags.syn == 0 && tcp.flags.ack == 1 && tcp.flags.reset == 0`

tcp.flags.syn == 0 && tcp.flags.ack == 1 && tcp.flags.reset == 0							
No.	Time	Source	Destination	Protocol	Length	Info	
6	23.764815289	192.168.200.100	192.168.200.150	TCP	66	53060 → 80	[ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810522428 TSecr=42...
24	36.774709464	192.168.200.100	192.168.200.150	TCP	66	41304 → 23	[ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535438 TSecr=42...
25	36.774711072	192.168.200.100	192.168.200.150	TCP	66	56120 → 111	[ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535438 TSecr=42...
28	36.775174048	192.168.200.100	192.168.200.150	TCP	66	41182 → 21	[ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535438 TSecr=42...
37	36.775803786	192.168.200.100	192.168.200.150	TCP	66	55656 → 22	[ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535439 TSecr=42...
38	36.775813232	192.168.200.100	192.168.200.150	TCP	66	53062 → 80	[ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535439 TSecr=42...
65	36.776914772	192.168.200.100	192.168.200.150	TCP	66	33042 → 445	[ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535440 TSecr=42...
66	36.776941020	192.168.200.100	192.168.200.150	TCP	66	46990 → 139	[ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535440 TSecr=42...
67	36.776962320	192.168.200.100	192.168.200.150	TCP	66	60632 → 25	[ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535440 TSecr=42...
68	36.776983878	192.168.200.100	192.168.200.150	TCP	66	37282 → 53	[ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535440 TSecr=42...
165	36.781512468	192.168.200.100	192.168.200.150	TCP	66	45648 → 512	[ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535445 TSecr=42...
268	36.788833247	192.168.200.100	192.168.200.150	TCP	66	51396 → 514	[ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535452 TSecr=42...
997	36.825733908	192.168.200.100	192.168.200.150	TCP	66	42048 → 513	[ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535489 TSecr=42...

Filtro applicato per evidenziare le porte risultate aperte: le porte di destinazione (23, 80, 111, 22, 21, 445, 139, 25, 53, 512, 513, 514) corrispondono ai servizi attivi su Metasploitable.

Ho poi verificato il range di porte scansionato applicando un secondo filtro per i pacchetti SYN con porta superiore a 1000, per confermare che la scansione coprisse tutto il range 1-1024:

- `tcp.port > 1000 && tcp.flags.syn == 1`

tcp.port > 1000 && tcp.flags.syn == 1							
No.	Time	Source	Destination	Protocol	Length	Info	
825	36.816660499	192.168.200.100	192.168.200.150	TCP	74	46296 → 871	[SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=...
827	36.816751822	192.168.200.100	192.168.200.150	TCP	74	48890 → 477	[SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=...
828	36.816871058	192.168.200.100	192.168.200.150	TCP	74	51980 → 340	[SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=...
829	36.816977498	192.168.200.100	192.168.200.150	TCP	74	52046 → 553	[SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=...
830	36.817062050	192.168.200.100	192.168.200.150	TCP	74	48512 → 1001	[SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=...
831	36.817137415	192.168.200.100	192.168.200.150	TCP	74	46368 → 523	[SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=...
838	36.817331544	192.168.200.100	192.168.200.150	TCP	74	37738 → 1024	[SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=...
839	36.817365160	192.168.200.100	192.168.200.150	TCP	74	34820 → 927	[SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=...
840	36.817380601	192.168.200.100	192.168.200.150	TCP	74	39418 → 228	[SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=...
841	36.817414924	192.168.200.100	192.168.200.150	TCP	74	52294 → 27	[SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=...
842	36.817494947	192.168.200.100	192.168.200.150	TCP	74	57132 → 824	[SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=...
847	36.817672819	192.168.200.100	192.168.200.150	TCP	74	50128 → 346	[SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=...
849	36.817826844	192.168.200.100	192.168.200.150	TCP	74	36864 → 727	[SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=...
850	36.817847957	192.168.200.100	192.168.200.150	TCP	74	42070 → 923	[SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=...
851	36.817883570	192.168.200.100	192.168.200.150	TCP	74	42688 → 259	[SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=...
853	36.818024451	192.168.200.100	192.168.200.150	TCP	74	60898 → 947	[SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=...
857	36.818216983	192.168.200.100	192.168.200.150	TCP	74	46718 → 741	[SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=...
860	36.818438901	192.168.200.100	192.168.200.150	TCP	74	40302 → 866	[SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=...
861	36.818614519	192.168.200.100	192.168.200.150	TCP	74	55344 → 52	[SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=...
863	36.818769087	192.168.200.100	192.168.200.150	TCP	74	39996 → 609	[SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=...

La presenza di ACK che completano il **handshake** è la prova che si tratta di un **TCP Connect Scan** (-sT).

IOC IDENTIFICATI

Dall'analisi della cattura ho identificato i seguenti Indicatori di Compromissione:

- **PORT SCAN MASSIVO**: decine di SYN verso porte diverse in pochi decimi di secondo, con un singolo IP sorgente (192.168.200.100). Il pattern è incompatibile con traffico legittimo.
- **NETBIOS HOST**: il pacchetto BROWSER della prima riga espone il nome host e il ruolo della macchina vittima sulla rete, fornendo all'attaccante informazioni di ricognizione senza alcuna interazione attiva.
- **VELOCITÀ ANOMALA DEL TRAFFICO**: tutti i pacchetti si concentrano in una finestra temporale di pochi secondi, cosa che fa usualmente *nmap*.

VETTORI DI ATTACCO IPOTIZZATI

In base agli IOC rilevati, la scansione nmap è probabilmente stata eseguita con il comando:

- `nmap -sT -p 1-1024 192.168.200.150`

La scansione ha rivelato diverse porte aperte su Metasploitable, ognuna delle quali rappresenta un potenziale vettore per una fase di exploitation successiva, ne evidenzio alcune:

- **FTP (PORTA 21):** vsftpd 2.3.4 presente su Metasploitable contiene una backdoor documentata attivabile con uno specifico pattern nell'username.
- **TELNET (PORTA 23):** servizio non cifrato con credenziali in chiaro, facilmente sfruttabile per accesso diretto.
- **HTTP (PORTA 80):** grazie alla presenza di DVWA, vulnerabile a SQL Injection, XSS e altri attacchi applicativi.

RACCOMANDAZIONI

Per mitigare l'attacco in corso e prevenirne di simili in futuro, propongo le seguenti azioni:

- **INSTALLARE E CONFIGURARE UN IPS** (Intrusion Prevention System): a differenza di un IDS che si limita a rilevare e avvisare, l'IPS blocca attivamente il traffico sospetto. Con regole specifiche per il rilevamento di port scan (es. soglia di SYN per unità di tempo da uno stesso IP), è in grado di interrompere automaticamente la scansione prima che l'attaccante completi la ricognizione;
- **DISABILITARE O FILTRARE IL PROTOCOLLO NETBIOS;**
- **VALUTAZIONE DEI SERVIZI ESPOSTI:** rimuovere o disabilitare i servizi non necessari (Telnet, R-services, FTP con backdoor), aggiornare quelli vulnerabili e isolare il resto tramite segmentazione di rete e regole firewall restrittive.

CONCLUSIONI

L'analisi della cattura Wireshark ha permesso di identificare con chiarezza una fase di ricognizione attiva condotta tramite nmap su tutto il range di porte 1-1024. Il pattern del traffico, la velocità anomala dei pacchetti e il NetBIOS Host costituiscono IOC concreti e rilevabili.

La varietà di servizi vulnerabili esposti dalla macchina vittima suggerisce che la ricognizione fosse solo l'inizio a un tentativo di exploitation mirato. L'adozione di un IPS con regole di rate limiting sui SYN, combinata con una rimozione/filtraggio dei servizi esposti, rappresenta la contromisura più efficace per bloccare questo tipo di attacco sia nella fase di scansione che in una eventuale fase successiva.